

GRC Compliance Policy Framework

Multi-Country Banking Operations

Document Type:	Compliance Policy Framework
Version:	1.0
Date:	October 2025
Scope:	Global Banking Operations
Standards:	PCI DSS, ISO 27001, SWIFT CSP, Local Regulations

Table of Contents

- 1. Executive Summary
- 2. Purpose and Scope
- 3. Regulatory Framework Alignment
- 4. Global Standards Compliance
- 5. Policy Development Framework
- 6. Evidence Management System
- 7. Roles and Responsibilities
- 8. Compliance Monitoring and Reporting
- 9. Audit and Assessment Framework
- 10. Training and Awareness
- 11. Implementation Roadmap
- 12. Appendices

1. Executive Summary

This GRC Compliance Policy Framework establishes a comprehensive approach for multi-country banking operations to ensure adherence to global standards (PCI DSS, ISO 27001, SWIFT CSP) and local regulatory requirements. The framework provides structured guidance for policy development, evidence management, and compliance monitoring across diverse regulatory environments.

2. Purpose and Scope

2.1 Purpose

- Establish standardized compliance processes across all banking operations
- Ensure consistent adherence to global standards and local regulations
- Provide clear guidance for policy development and evidence management
- Enable effective monitoring and reporting of compliance status
- Support internal and external audit requirements

2.2 Scope

This policy applies to:

- All banking entities across multiple countries
- All employees, contractors, and third-party service providers
- All systems, processes, and data handling activities
- All compliance-related documentation and evidence

3. Regulatory Framework Alignment

3.1 Global Standards

Standard	Scope	Key Requirements
PCI DSS	Payment Card Data	Secure cardholder data environment
ISO 27001	Information Security	ISMS implementation and certification
SWIFT CSP	Financial Messaging	Secure financial message exchange
Basel III	Capital Requirements	Risk management and capital adequacy

3.2 Local Regulatory Requirements

Each country operation must maintain compliance with: • Central bank regulations and guidelines • Data protection and privacy laws (GDPR, local equivalents) • Anti-money laundering (AML) and counter-terrorism financing (CTF) requirements • Consumer protection regulations • Operational risk management requirements

4. Global Standards Compliance

4.1 PCI DSS Compliance Framework

• Maintain secure network architecture and cardholder data environment • Implement strong access control measures and authentication protocols • Regular vulnerability management and security testing • Comprehensive logging and monitoring of all access to network resources • Annual compliance validation through qualified security assessors

4.2 ISO 27001 Information Security Management

• Establish and maintain Information Security Management System (ISMS) • Conduct regular risk assessments and implement appropriate controls • Ensure business continuity and disaster recovery capabilities • Maintain security awareness training programs • Annual certification audits and continuous improvement processes

4.3 SWIFT Customer Security Programme

• Implement mandatory security controls for SWIFT infrastructure • Secure SWIFT-related infrastructure and reduce attack vectors • Detect and respond to cyber threats targeting SWIFT environment • Share cyber threat intelligence with SWIFT community • Annual self-attestation and independent assessment requirements

5. Policy Development Framework

5.1 Policy Hierarchy

Level	Document Type	Approval Authority	Review Frequency
1	Corporate Policies	Board of Directors	Annual
2	Operational Procedures	Executive Management	Bi-annual
3	Technical Standards	Department Heads	Quarterly
4	Work Instructions	Team Leaders	As needed

5.2 Policy Development Process

1. **Requirement Analysis:** Identify regulatory requirements and business needs 2. **Gap Assessment:** Compare current state with required compliance standards 3. **Policy Drafting:** Develop comprehensive policy documentation 4. **Stakeholder Review:** Obtain input from relevant business units and compliance teams 5. **Approval Process:** Secure formal approval from designated authorities 6. **Implementation:** Deploy policies with appropriate training and communication 7. **Monitoring:** Establish ongoing compliance monitoring and reporting 8. **Review and Update:** Regular review cycles to ensure continued effectiveness

6. Evidence Management System

6.1 Evidence Categories

Documentation Evidence: • Policy documents and procedures • Risk assessments and mitigation plans • Training records and certifications • Incident reports and remediation actions **Technical Evidence:** • System configurations and security settings • Vulnerability scan reports and penetration test results • Access control matrices and user privilege reviews • Backup and recovery test results **Operational Evidence:** • Audit logs and monitoring reports • Change management records • Business continuity test results • Vendor management assessments

6.2 Evidence Collection and Storage

• Centralized evidence repository with role-based access controls • Automated evidence collection where possible through integrated systems • Standardized evidence templates and submission processes • Version control and audit trail for all evidence documents • Secure storage with encryption and backup capabilities • Retention policies aligned with regulatory requirements

7. Roles and Responsibilities

Role	Primary Responsibilities
Chief Risk Officer (CRO)	Overall GRC strategy and governance
Chief Information Security Officer (CISO)	Information security and cyber risk management
Compliance Officer	Regulatory compliance monitoring and reporting
Risk Managers	Risk assessment and mitigation planning
Business Unit Heads	Operational compliance within their domains
IT Security Teams	Technical security controls implementation
Internal Audit	Independent compliance assessment and validation
All Employees	Adherence to policies and reporting of issues

8. Compliance Monitoring and Reporting

8.1 Continuous Monitoring

• Real-time monitoring of critical security controls and compliance metrics • Automated alerts for policy violations and control failures • Regular compliance assessments and gap analysis • Key Risk Indicators (KRIs) and Key Performance Indicators (KPIs) tracking • Dashboard reporting for management visibility

8.2 Reporting Framework

Executive Reporting: Monthly compliance scorecards and risk dashboards **Regulatory Reporting:** Periodic submissions to regulatory authorities **Board Reporting:** Quarterly comprehensive compliance and risk reports **Operational Reporting:** Weekly operational risk and incident reports **Audit Reporting:** Annual compliance assessment and audit results

9. Audit and Assessment Framework

9.1 Internal Audit Program

• Risk-based audit planning aligned with regulatory requirements • Regular compliance audits covering all major risk areas • Follow-up on audit findings and remediation tracking • Quality assurance and continuous improvement of audit processes

9.2 External Audit and Assessment

• Annual external audits for regulatory compliance validation • Third-party security assessments and penetration testing • Certification audits for ISO 27001 and other standards • Regulatory examinations and supervisory reviews

10. Training and Awareness

Mandatory Training Programs: • Annual compliance and ethics training for all employees • Role-specific training for compliance and risk management staff • Security awareness training with regular updates • Regulatory training for customer-facing staff **Awareness Initiatives:** • Regular communication of policy updates and regulatory changes • Compliance newsletters and best practice sharing • Incident case studies and lessons learned sessions • Recognition programs for compliance excellence

11. Implementation Roadmap

Phase	Timeline	Key Activities	Deliverables
Phase 1	Months 1-3	Policy framework development	Core policies and procedures
Phase 2	Months 4-6	System implementation	Evidence management system
Phase 3	Months 7-9	Training and rollout	Training programs and awareness
Phase 4	Months 10-12	Monitoring and optimization	Compliance dashboards and reports

12. Appendices

Appendix A: Regulatory Mapping Matrix **Appendix B:** Policy Templates and Standards **Appendix C:** Evidence Collection Checklists **Appendix D:** Compliance Monitoring Metrics **Appendix E:** Training Curriculum and Materials **Appendix F:** Incident Response Procedures